

PROJECT 6 — ATO DETECTION LAB

Complete Wazuh Rules Changelog

Every rule created, revised, and fixed — Phase 5 through Phase 9

35 total changes across 9 distinct rules and 1 custom decoder, tracked from first draft to final working version.

Vignesh Gopal Kalaivani

Summary

Metric	Count
Total individual rule/decoder changes made	35
Distinct rule IDs created	9 (100100–100108)
Custom decoders created	1 (securebank-session, with 1 parent + 1 child definition)
Rules that worked correctly on the first attempt	5 (100100, 100101, 100102, 100105, 100108)
Rules that required at least one fix before working	4 (100103, 100104, 100106, and the decoder itself)
Distinct root causes discovered through debugging	9
Rule reordering events required	3 separate occasions

Section A — Phase 5 Rules (Original ATO Detection)

Rule 100100 — Base login endpoint matcher

Created once. Worked as designed — a level-0 matcher with no alerting, used purely so other rules could chain off it. No revisions needed.

Rule 100101 — Failed login

Created once. Worked correctly on first test via wazuh-logtest. No revisions needed.

Rule 100102 — Credential stuffing burst

Created once. Worked correctly. No revisions needed.

Rule 100103 — Login success (1 fix required)

Version	Change	Result
v1	if_sid set to 31100 (assumed parent rule)	Did not fire — 31100 does not catch 2xx status responses
v2 (final)	Changed if_sid to 31108 (the rule actually matching this traffic, confirmed via wazuh-logtest)	Fired correctly

Rule 100104 — Account Takeover correlation (1 fix required)

Version	Change	Result
v1	frequency set to 1	Rejected outright by Wazuh: "Invalid frequency: 1. Must be higher than 1."
v2 (final)	Changed frequency to 2	Loaded and fired correctly — this is also the logically correct value, since the rule requires two co-occurring signals

Section B — Phase 9, Task 1 (Sensitive Action Step-Up)

Custom Decoder — securebank-session (3 fixes required)

Version	Change	Result
v1	Child decoder used offset="after_regex"	Invalid — Wazuh rejected the config; only after_parent / after_prematch are valid offset values
v2	Fixed offset to after_parent; regex written using OSRegex-style \S+ syntax	Parent matched, but child extracted zero fields — silent failure, no error shown

v3 (final)	Added type="pcre2" to the regex tag, switching to the standard PCRE2 engine	All four fields (event_type, session_id, user, srcip) extracted correctly
------------	---	---

A related discovery (not a fix, a platform behavior): the field named "user" in the <order> tag was automatically renamed to "dstuser" by Wazuh, since user is a reserved static field name. The extracted value was correct throughout; only the field name differed from what was specified.

Rule 100105 — Sensitive action without step-up

Created once, using the newly working decoder. Matched correctly in wazuh-logtest on the first attempt.

However, the rule did not fire against LIVE traffic despite working in isolated testing. Root cause: the original error_log() calls in transfer.php did not include a trailing newline character, causing every log line to run together into one unparseable block. Fixed by adding \n to both error_log() calls in transfer.php and clearing the malformed file with sudo truncate -s 0. This was an application-logging fix, not a rule fix, but was required before rule 100105 could fire on real traffic.

Section C — Phase 9, Task 2 (Session Hijack Detection)

This section required by far the most iteration — 4 distinct root causes across roughly 20 individual changes before a working rule was achieved.

Rule 100107 — Base correlation anchor (created, then later removed entirely)

Version	Change	Result
v1	Independent match on decoded_as securebank-session	Competed with the more specific rule 100105 for the same log lines and lost — Wazuh assigns one winning rule per log line
v2	Changed to if_sid 100105 (chained specifically to Task 1's rule)	Too narrow — only fired for SENSITIVE_ACTION_NO_STEPUP events, missed SESSION_CREATED entirely
(duplicate)	This rule was accidentally pasted into the file twice during editing	Caused Wazuh to reject the whole ruleset with a 'duplicated ID' warning; found via grep, removed via sed
(cleanup)	The duplicate-removal edit left an orphaned, unclosed XML fragment behind	Found via a wider sed -n view; removed with a second precise sed -i deletion
(removed)	Rule 100107 was ultimately deleted entirely	Replaced by a group-tag-based design (see rule 100108 and updated 100103/100105 below)

Rules 100103 and 100105 — Retrofitted with a shared group tag

Both rules had <group>session_event,</group> added to their existing <group> tags, so they could participate in a group-based correlation without needing rule 100107 as an intermediary.

Rule 100108 — Session created (new rule)

Created once, tagged with <group>session_event,</group> from the start. Matched correctly on the first test.

Rule 100106 — Session hijack correlation (the core rule, 6 fixes required)

Version	Change	Result
v1	if_matched_sid 100107, same_field session_id, different_field srcip	"Signature ID '100107' was not found" — rule 100107 was defined AFTER rule 100106 in the file
v2	Reordered file so 100107 came first	"Not found" error resolved, but rule 100106 still never fired against test data
v3	Switched from if_matched_sid to if_matched_group session_event (after redesigning 100107/100108/group tags)	Caused a hard CONFIG ERROR on service restart: "Invalid use of frequency/context options, missing if_matched" — the plain if_group tag is not valid alongside frequency/timeframe
v4	Changed if_group to if_matched_group	Service started cleanly, but the correlation still did not fire on two matching test events
v5	Isolation test: same_field session_id, then same_field dstuser, tested with two nearly identical synthetic log lines	Neither worked — ruled out the custom field itself and pointed to same_field/different_field not

		functioning as expected in this environment
v6	Switched from if_matched_group back to if_matched_sid 100108, to isolate one variable at a time	"Signature ID '100108' was not found" — the same ordering bug recurred, since 100108 was defined after 100106 again at this point
v7	Reordered file again so 100108 came before 100106	Ordering fixed
v8	Replaced same_field/different_field's 'same' side with the dedicated <same_user /> tag, kept different_field for srcip, kept if_matched_sid 100108	Fired correctly for the first time, on a controlled synthetic test
v9 (final)	Broadened back to if_matched_group session_event (with same_user and different_field srcip retained), file reordered a final time so all session_event-tagged rules precede 100106	Fired correctly against real, captured hijack evidence, and confirmed live against actual replayed attacker traffic

Root Causes Discovered (Full List)

#	Root Cause	Where Encountered
1	Wrong built-in parent rule assumed (31100 vs the actual match, 31108)	Rule 100103
2	Wazuh rejects frequency values below 2 for correlation rules	Rule 100104
3	Invalid decoder offset value (after_regex does not exist)	Custom decoder v1
4	OSRegex (Wazuh's default) does not support \S+ or similar standard regex syntax	Custom decoder v2
5	Reserved field names (e.g. "user") are silently remapped by Wazuh (to "dstuser")	Custom decoder (behavior, not a bug)
6	Missing newline characters in application logs merge all lines into one unparseable block	Rule 100105 (live traffic)
7	Rule dependency tags (if_sid, if_matched_sid, if_matched_group) fail silently/loudly if the referenced rule or group is defined later in the file	Rules 100106/100107/100108 (hit 3 times)
8	Frequency/timeframe correlation requires the "matched" variant of dependency tags — plain if_group causes a hard config error	Rule 100106
9	Generic same_field/different_field tags do not reliably correlate certain fields; dedicated composite tags (same_user, same_source_ip) must be used instead	Rule 100106 — the most significant finding of the whole task

Final, Working Rule Set (as deployed)

```

Rule 100100 (level 0) - Base: any request to /securebank/login.php
Rule 100101 (level 5) - Failed login (401)
Rule 100102 (level 10) - Credential stuffing burst (6+ fails/60s, same IP)
Rule 100103 (level 3) - Login success (chained to 31108), group: session_event
Rule 100104 (level 14) - ATO confirmed: stuffing burst + success, same IP
Rule 100105 (level 10) - Sensitive action without step-up, group: session_event
Rule 100108 (level 1) - Session created, group: session_event
Rule 100106 (level 12) - Session hijack: same user, different IP,
                        via if_matched_group session_event + same_user

```

Nine rules, one custom decoder, thirty-five individual iterations, nine distinct platform-level root causes identified and resolved.